Charles Goodsir

goodsirces@gmail.com linkedin.com/in/charles-goodsir github.com/charles-goodsir charlesgoodsir.com Auckland, NZ

PROFESSIONAL SUMMARY

Application engineer with 5+ years delivering enterprise CRM/ERP systems for NZ and AU councils, now moving into application security and DevOps. I built a gated CI/CD security pipeline around a vulnerable-by-design app, a Terraform-managed Azure landing zone that only deploys through a scanned, approved plan, and a threat-modelled expense claims system on Azure that survived 28 attacks on its own access control. Security+ certified, PortSwigger SQLi and XSS paths complete. Open to remote roles, and to roles in Auckland, Melbourne or London.

CORE COMPETENCIES

Application Security | Secure CI/CD Pipelines | Terraform & Azure | Azure DevOps & GitHub Actions | SAST, DAST & SCA | OWASP Top 10 | Python & Bash | Enterprise SDLC

WORK EXPERIENCE

Datacom Solutions

Sep 2021 - Present

Application Engineer, Finance Domain

Auckland, NZ

- Helped cut configuration defect rates by **~30%** for NZ & AU council clients by standardising testing.
- Authored YAML-driven test-data configuration in Azure DevOps, layered on top of an existing C# codebase, to provision cross-referenced data for local and cloud environments at build time.
- Built local council environments with .NET tooling and exported their configuration as JSON for the pipeline that builds each council's cloud environment.
- Ran planning sessions and live demos for a new enterprise finance module across 3 councils.
- Mentored junior engineers on testing and configuration standards.

Datacom Solutions (MBIE)

Sep 2020 - Sep 2021

Service Desk Analyst

Wellington, NZ

- Resolved 200+ IT incidents a month for the Ministry of Business, Innovation and Employment, with first-call resolution above 80%.
- Cut repeat support volume by 25% by spotting recurring issues and writing knowledge-base articles the wider team adopted.

SKILLS

Security: Burp Suite, Semgrep (SAST), gitleaks (secrets), Trivy (container/IaC scanning), OWASP ZAP (DAST), Dependabot (SCA), OWASP Top 10, NIST CSF 2.0, CSP & security headers, secure CI/CD pipeline design, STRIDE threat modelling, Entra ID & OAuth 2.0, Microsoft Sentinel (KQL), Defender for Cloud, Azure Policy, threat-oriented UAT

Cloud & Infra: Azure, Azure DevOps (Pipelines, self-hosted agents), Terraform, Docker, Linux, nginx, AWS (Lambda, API Gateway, SAM, DynamoDB, EventBridge, CloudWatch, Lightsail), Cloudflare Workers + KV, .NET tooling, Supabase (Postgres + PostGIS), Firestore, CI/CD (Azure Pipelines, GitHub Actions, Expo EAS), Git

Languages: TypeScript, JavaScript, Python, SQL, Bash, YAML/JSON (config authoring), HTML/CSS. C# and ASP.NET Core (an API written as a guided code-along project); otherwise works within existing C# codebases via configuration.

Frameworks: React Native, React, Node.js, ASP.NET Core, FastAPI **Tools:** Confluence, Jira, Miro

Practices: Agile/Scrum, secure application design, incident triage, technical documentation, mentoring

PROJECTS

Secure Expense Claims Complete

Wrote a STRIDE threat model of 24 threats before any code, then built an expense claims system with ownership checks inside every query, separation of duties on approvals and an audit row written in the same transaction as each change. 65 API tests run against real Postgres and Azurite.

Deployed it to Azure with no secrets: the pipeline signs in with OIDC, the app uses a managed identity, the plan identity is read-only, every apply waits for approval, and a weekly drift check compares Azure with the code.

Attacked my own access control with 28 attacks using real Entra ID tokens for each role (IDOR, self-approval, tampering, forged tokens). None got through.

Added 8 Azure policies assigned by hand so the pipeline cannot remove them, triaged 11 Defender recommendations (3 fixed, 5 accepted with a reason, 2 stale), and made receipt downloads fail closed unless Defender's malware scan tagged the file clean.

Wrote 2 Sentinel detection rules as Terraform, tested on made-up log lines first and then on live traffic, where one raised a real incident.

ASP.NET Core, React, TypeScript, Postgres, Terraform, Azure (Entra ID, Policy, Defender, Sentinel), GitHub Actions, OIDC. Built as a guided code-along.

Personal Ops Platform In progress

Self-hosted an MCP server and Postgres on a home mini PC so Claude can search my notes and categorise bank transactions without the raw data leaving the box. Auth is rotating bearer tokens with a Host allowlist, behind a DOCKER-USER firewall rule.

Wrote a 22-threat STRIDE model, then about 200 attack tests against my own server. They found 17 problems, none a way in from outside, and I broke each fix on purpose to check its test fails.

Built a read-only dashboard on its own Postgres role (SELECT on four tables), with 31 attack tests and a live retest on the mini PC.

TypeScript, MCP, Postgres, Docker Compose, Telegram, Akahu

appsec-homelab Complete

Built a vulnerable-by-design ASP.NET Core 8 / React app with four seeded vulnerabilities (SQL injection x2, reflected XSS, plaintext password storage), then exploited, fixed, re-tested and documented each one.

Built a defense-in-depth CI/CD security pipeline with parallel jobs: secrets (gitleaks), SAST (Semgrep), build, SCA (Dependabot), test, and container scanning (Trivy), plus DAST (OWASP ZAP) and a reviewer-approval gate before production.

Hardened the frontend's nginx config over three rounds of ZAP scans (CSP, X-Frame-Options, X-Content-Type-Options, Permissions-Policy, cross-origin isolation headers), cutting warnings from 8 to 3.

ASP.NET Core 8, React, nginx, Docker, GitHub Actions, Azure Pipelines, Semgrep, gitleaks, Trivy, OWASP ZAP

Secure Azure Landing Zone Complete

Built a Terraform-managed Azure landing zone pipeline-first (resource group, VNet and subnet, deny-by-default NSG, storage account, Key Vault with RBAC and purge protection): a 5-stage Azure DevOps pipeline validates, runs a security scan, plans, and waits for manual approval before any change reaches Azure.

Made the security scan a hard gate. Apply runs only the saved plan artifact a reviewer approved, and the pipeline authenticates with workload identity federation (OIDC): no stored client secret.

Triaged 6 scanner findings on my own Terraform: fixed 4, including a CRITICAL Key Vault with no network ACL, and accepted 2 with a written reason next to the code and an expiry date.

Terraform, Azure, Azure DevOps, Trivy, OIDC, YAML

Detour: Cross-Platform Mobile App (Solo Developer) Live on App Store

Built a full-stack mobile app with React Native, TypeScript, Supabase, and Firestore handling auth, geolocation, real-time data, and social features.

Implemented Supabase Auth with row-level security policies restricting each user to their own data.

React Native, TypeScript, Supabase, Firestore, PostGIS

EDUCATION

Level 6 Diploma in Applied Software Development Dev Academy Aotearoa 2023 - 2024

BA in History, International Relations & Political Science Victoria University of Wellington 2017 - 2020

CERTIFICATIONS

CompTIA Security+ (SY0-701) CompTIA Jul 2026